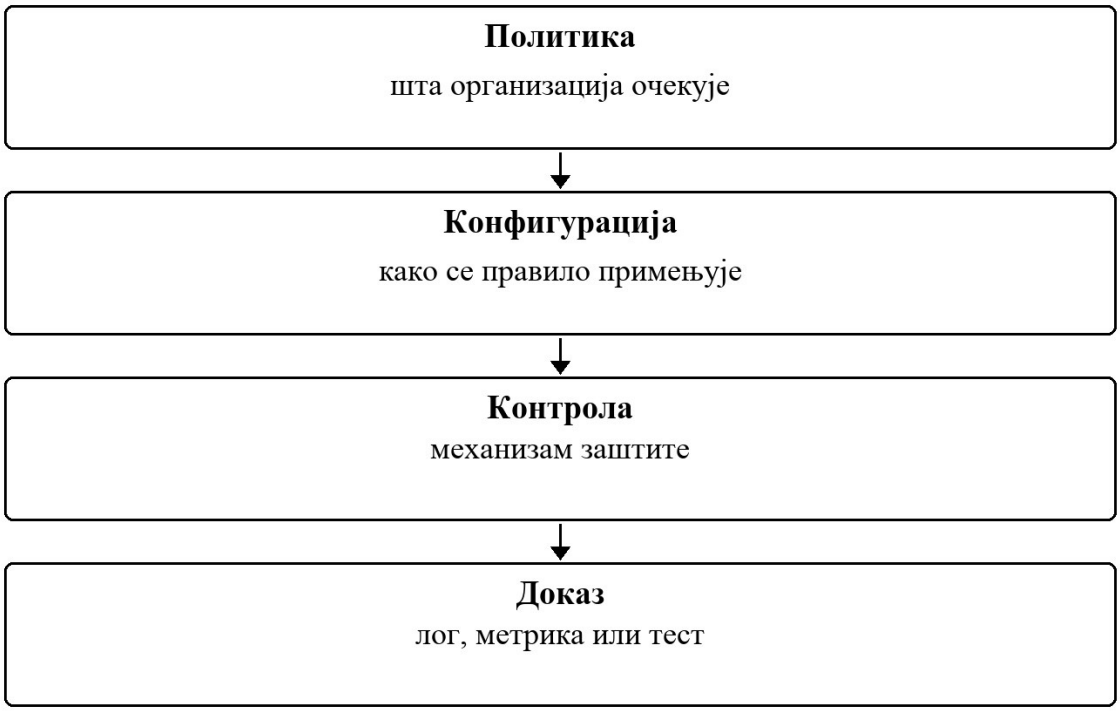
Политике, конфигурација и безбедносна видљивост

Основе информационе безбедности · 03

Безбедносна правила постају поуздана тек када су видљива, верзионисана и проверљива. Правило расуто кроз неколико метода није лако објаснити, прегледати нити променити без нежељених последица. Политика зато представља договорено правило, а конфигурација његову примену у конкретном окружењу.

Видљивост не служи само реаговању на инцидент. Она омогућава тиму да разуме одлуку система, прати одступање од очекиваног стања и повеже догађаје кроз различите слојеве апликације.



Слика 1. Експлицитна правила уместо безбедности скривене у коду

Безбедносна одлука настаје повезивањем приказаних појмова.

Циљ вежбе

Студент треба да образложи одлуку система, податке на којима се она заснива и њен утицај на заштиту података и услуга.

3.1 Правило без доказа је само намера

Видљивост не служи само реаговању на инцидент. Она омогућава тиму да разуме одлуку система, прати одступање од очекиваног стања и повеже догађаје кроз различите слојеве апликације.

- Нова верзија политике не брише разлог због ког је стара одлука некада била исправна.
- Конфигурациона вредност има власника, значење и очекивани опсег.
- Корелациони идентификатор повезује један безбедносни ток кроз слојеве система.

Питање за дискусију

Које безбедносно правило би требало да буде засебан, читљив артефакт у вашој целини и који доказ показује да ради?

3.2 Како се ова тема види у развоју

Тим бира неколико кључних одлука које мора моћи да објасни из лога и теста. То нису сви догађаји система, већ они чији би нејасан исход отежао истрагу, преглед приступа или корекцију конфигурације.

Честе грешке које треба препознати

- Уређивање објављене политике на месту без историје.
- Тајне у конфигурационим датотекама или логовима.
- Метрика без јасног питања на које треба да одговори.

Веза са осталим темама

Разматрана одлука повезује идентитет, податке, политике и доказе, а исти поступак анализе примењује се на различите врсте информационих система.

3.3 Пример: промена правила без губитка историје

Тим пооштрава правило за приступ административном интерфејсу. Ако старо правило само препише новим, касније не може да објасни зашто је ранији приступ био дозвољен нити да реконструише које је очекивање тада важило. Верзионисање не служи бирократији, већ очувању смисла историјских одлука.

- Политика описује намеру и важење, док конфигурација чува вредности којима се та намера примењује у окружењу.
- Свака промена која утиче на одлуку има власника, датум и јасан разлог.
- Лог, метрика или тест дају доказ да систем ради према активном правилу, а не само да је правило записано.

Критеријуми решења

Решење треба да буде образложено пословним контекстом, примењено на серверској страни и потврђено поновљивим тестом, ревизијским записом или демонстрацијом.

3.4 Дизајнерска одлука: правило мора имати границе

Политика постаје корисна када је довољно прецизна да људи доносе доследне одлуке, а довољно читљива да се може објаснити без читања изворног кода. Добро правило наводи на шта се односи, ко је власник, када важи и шта се дешава ако се правила сукобе.

- Конфликт политика решава се унапред договореним правилом, често рестриктивнијом одлуком.
- Конфигурација не мења смисао политике без видљивог процеса одобравања.
- Безбедносна контрола има власника и очекивани доказ, иначе нико не прати да ли је престала да ради.

3.5 Видљивост као способност тима

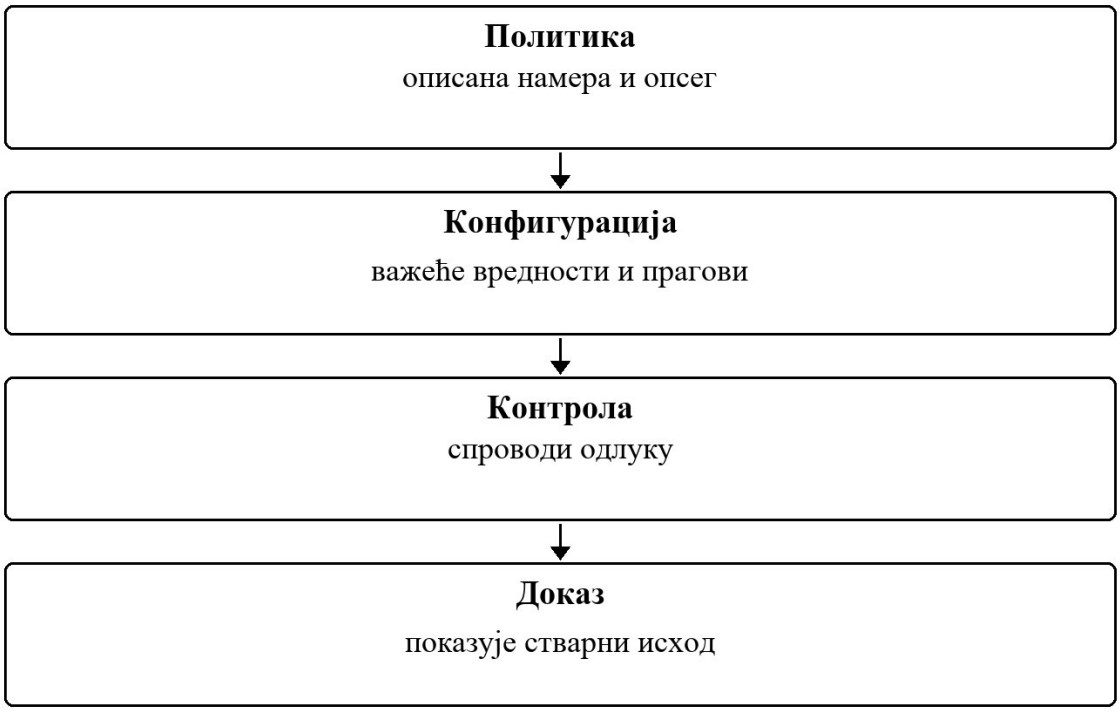
Опсервабилност подразумева да се за значајну одлуку може пронаћи одговарајући контекст: место настанка, ток кроз слојеве система и разлог успешног или одбијеног исхода. Корелациони идентификатор повезује записе који припадају истој операцији.

- Технички логови разликују се од безбедносно значајних ревизијских записа.
- Метрика има назив, власника и прецизно дефинисано питање на које одговара.
- Тајне, токени и непотребни лични подаци не бележе се у логове нити у ознаке метрика.

Самостална провера

За изабрани сценарио наведите одлуку система, коришћене податке, очекивани исход и доказ на основу ког други члан тима може да потврди резултат.

3.6 Шема од правила до доказа



Слика 2. Шема од правила до доказа

Правило може бити добро написано, а контрола ипак неефективна. Доказ повезује очекивање са реалним понашањем.

За сваки корак шеме одредите покретача, одлуку која се доноси и запис који остаје након извршења.

3.7 Политика, процедура и контрола

Табела 1. Елемент и Улога

Елемент	Улога	Пример доказа
Политика	Одређује правило и циљ заштите.	Верзионисан текст са власником.
Процедура	Описује како људи или систем спроводе правило.	Преглед корака или аутоматизовани ток.
Контрола	Спречава, открива или ограничава ризик.	Тест, лог или резултат провере.
Метрика	Показује тренд или одступање.	Дефинисан праг и извор података.

Тумачење поређења

Сваки појам описује посебан део безбедносне одлуке; тек њиховом правилном комбинацијом настаје целовит модел.

3.8 Како се бира безбедносна метрика

Метрика је корисна само ако води ка одлуци. Зато се не почиње бројем, већ питањем које оператер или власник система мора да реши. Затим се бира извор, период посматрања и праг при коме је потребна акција.

1. Које понашање желимо да разумемо или ограничимо?

2. Који догађаји поуздано представљају то понашање?

3. Ко је власник прага и шта ради када се праг пређе?

4. Како разликујемо нормалну промену рада од безбедносног одступања?

Исход учења

Студент треба да уме да изабере одговарајућа питања за анализу безбедносно значајне одлуке и да образложи редослед њихове примене.

Примена на пројекту

На додељеној пројектној целини применити принцип из теме „Политике, конфигурација и безбедносна видљивост". Идентификовати одлуку система, имплементирати је на серверској страни и припремити доказ у облику теста, ревизијског записа или демонстрације.

3.9 Извршиви пример

`ConfigurationDriftDetector` пореди активну конфигурацију са усвојеним баселине-ом. Контроле имплементирају `IConfigurationControl`; налаз означава слабљење заштите.

Пример 1. Покретање из репозиторијума наставног портала; потребан је доднет 8 СДК.

```
cd examples/oib-dotnet/vezba-03-politike-konfiguracija
dotnet run --project src/Oib.Vezba03.ConsoleUi
dotnet test Oib.Vezba03.sln
```

Табела 2. Провера и Садржај

Провера	Садржај
Сценарио	Минимална дужина лозинке или захтев за администраторски Вишефакторска аутентикација ослаби у односу на баселине.
Тестови	`ConfigurationControlTests`, `DetectConfigurationDriftHandlerTests`
Доказ	`DriftReport` садржи цоррелатион ИД и верзију баселине-а.

Задатак уз пример

Додати контролу за максимално трајање сесије: проширити `SecurityBaseline` и `SecurityConfiguration`, написати нову `IConfigurationControl` класу и тест који показује да дужа сесија од дозвољене даје налаз.